

European Standardization Organizations

CRA Standards Unlocked: Unlocking CRA Security Controls: preparation for UNE Event

*We start at
11:00 CET*

Webinar moderator



Els SOMERS

Project Manager

Public Relations

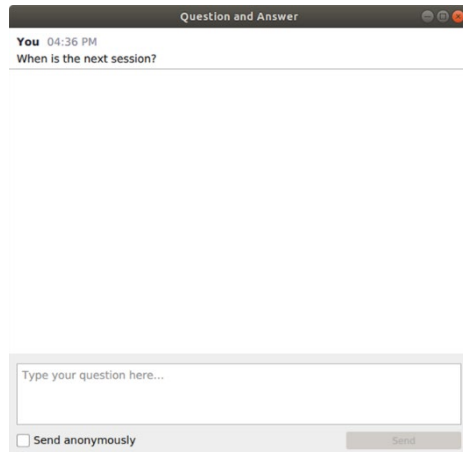
CEN-CENELEC

esomers@cencenelec.eu

Get the most out of the webinar today



- ▶ You are muted
- ▶ Use the Q&A panel to submit your questions

A screenshot of a 'Question and Answer' panel from a webinar. At the top, it says 'Question and Answer' with window control icons. Below that, it shows a message from 'You' at '04:36 PM' asking 'When is the next session?'. There is a large empty text area for typing a question. At the bottom, there is a text input field with the placeholder 'Type your question here...', a checkbox labeled 'Send anonymously', and a 'Send' button.

- ▶ Talk about us with #training4standards #standards4CRA
 - ▶ On X [@Standards4EU](#)
 - ▶ On Bluesky [@cen-cenelec.bsky.social](#)
 - ▶ On LinkedIn www.linkedin.com/company/cen-and-cenelec

► Introduction

- CRA standards and the standardization request
- What is a harmonized standard?
- Technical work
- Funding opportunities

► Presentation on Smart card and similar devices: focus on the application layer (Rapporteur Ivan Plajh)

Your speakers today



Lucia LANFRI

Project Manager Electrotechnology
Standardization & Digital Solutions



Angelo D'AMATO

Rapporteur CEN-CLC/JTC
13 WG 9, work item #2-14
CRA standardization
request



Amanda SUO

Secretariat UNE (Spanish standards),
CEN CENELEC member

- ▶ A **Standardization Request (SReq)** is a formal document issued by the European Commission (EC) to European Standardization Organizations (ESOs)—namely CEN, CENELEC, and ETSI—asking them to **develop, revise, or update harmonized standards** to support **EU policies or legislation**.
- ▶ M/606 “CRA” : [eNorm Platform](#)
- ▶ This request was accepted by CEN, CENELEC and ETSI

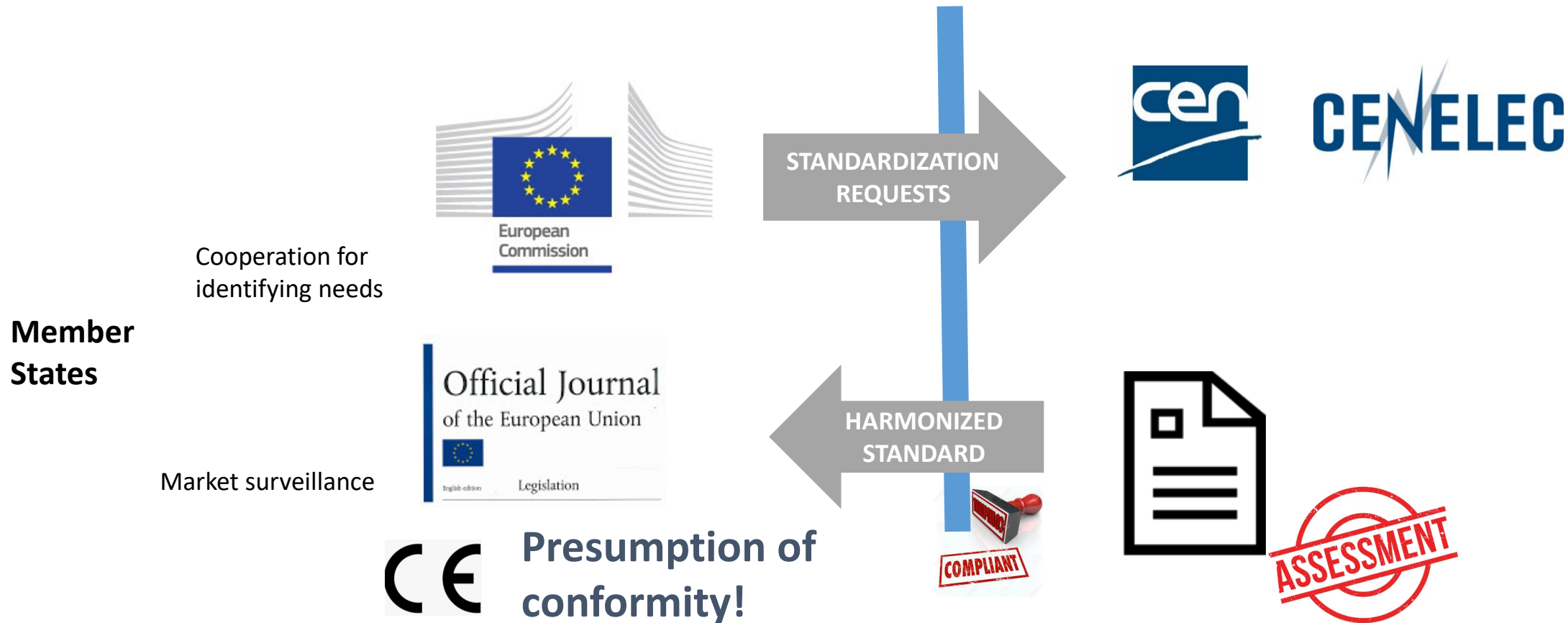
What is a harmonized standard?



- ▶ A harmonized standard is a European standard developed by recognized European Standards Organizations.
- ▶ It is created following a request from the European Commission to one of these organizations → Standardization Requests
- ▶ Their use is voluntary
- ▶ Manufacturers, other economic operators, or conformity assessment bodies can use harmonized standards to demonstrate that products, services, or processes comply with relevant EU legislation. They are free to choose another technical solution to demonstrate compliance with the mandatory legal requirements.
- ▶ The CRA is a first of its kind regulation, so no standards currently exist that specifically cover the CRA essential requirements.

Regulation 1025/2012 – Assessment, citation and Presumption of conformity

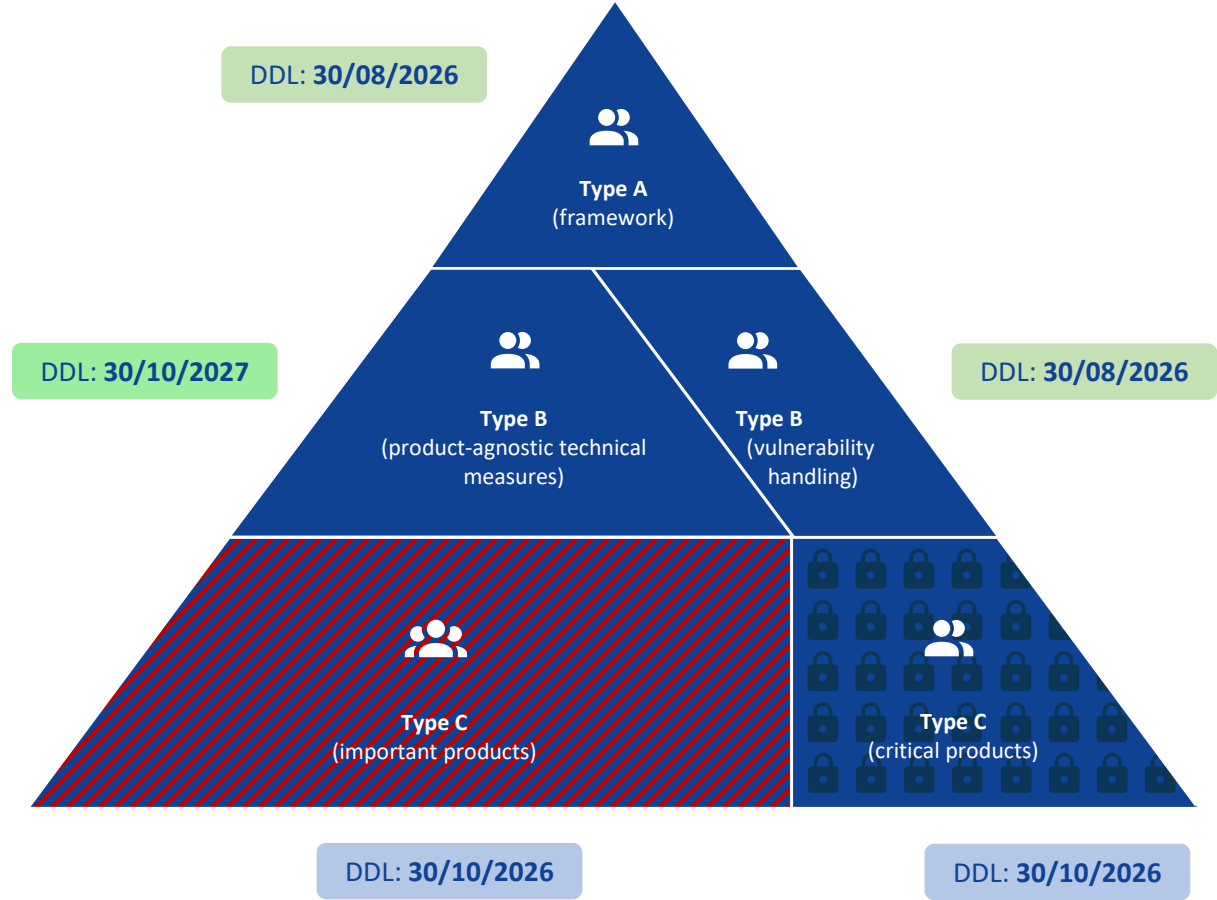
Reflects regulatory objectives!



CRA Harmonized standards

- ▶ Standards requested and work programme
- ▶ What are the timelines?
- ▶ How is the work organized?
- ▶ How to participate?

CRA SReq - deliverables requested



- ▶ 41 topics, 3 'types' of deliverables:
 - ▶ Category "A": horizontal framework
 - ▶ Only CEN and CENELEC
 - ▶ Topic #1 (JTC 13 WG9)
 - ▶ deadline 2026-08-30
 - ▶ Category "B": product-agnostic technical measures & vulnerability handling
 - ▶ Only CEN and CENELEC
 - ▶ Topic #2-15 (JTC 13 WG9)
 - ▶ Deadline 2027-10-30 (except for line 15 - vulnerability handling - 2026-08-30)
 - ▶ Category "C": Important and critical products
 - ▶ CEN, CENELEC **and ETSI**
 - ▶ Topic #16-38
 - ▶ deadline 2026-10-30
 - ▶ Only CEN and CENELEC
 - ▶ Topic #39-41
 - ▶ **Critical products**
 - ▶ deadline 2026-10-30

Correlation between the requested standards on M/606 and the technical committees at CEN, CENELEC and ETSI

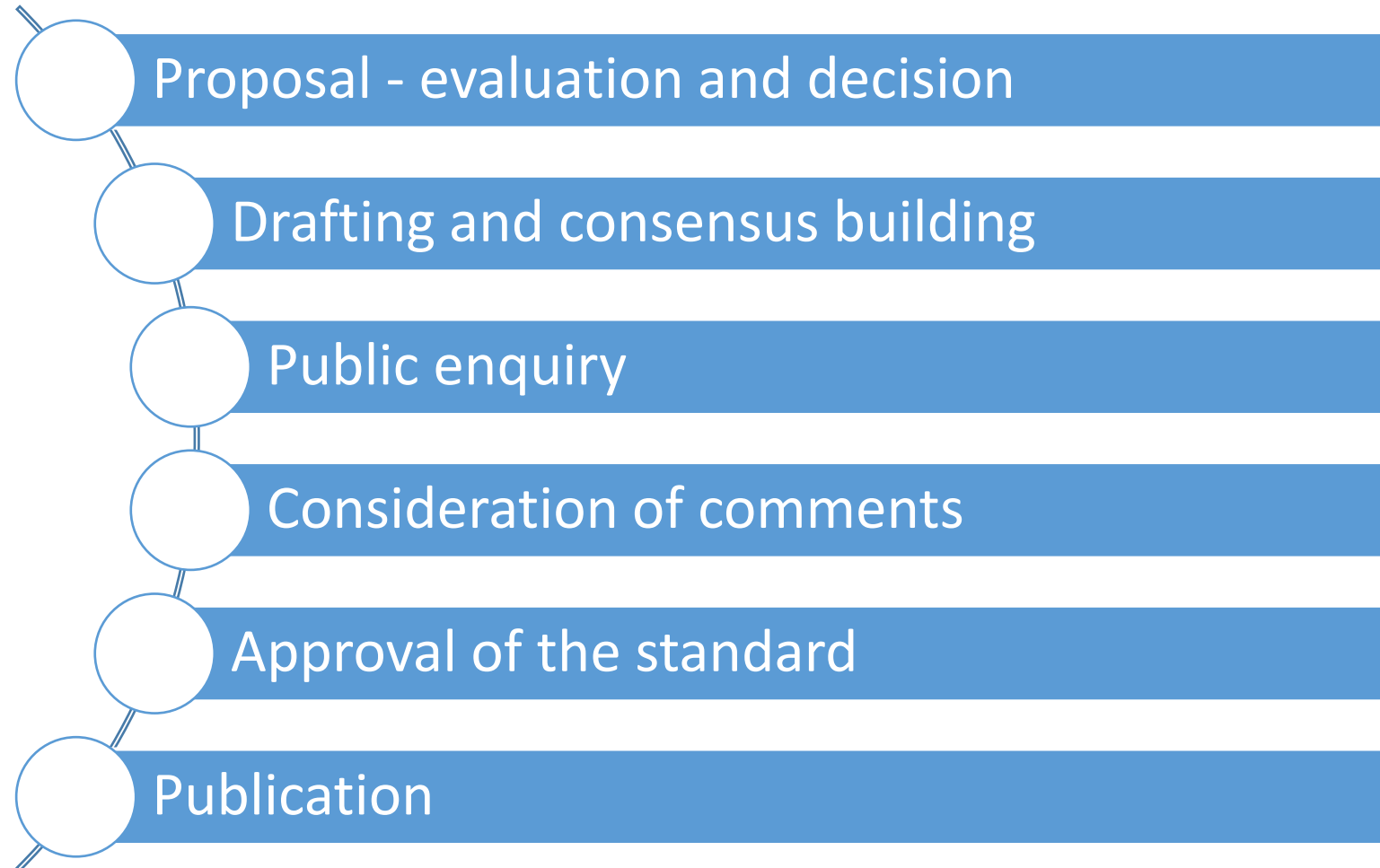


ANNEX I
List of new European Standards to be drafted

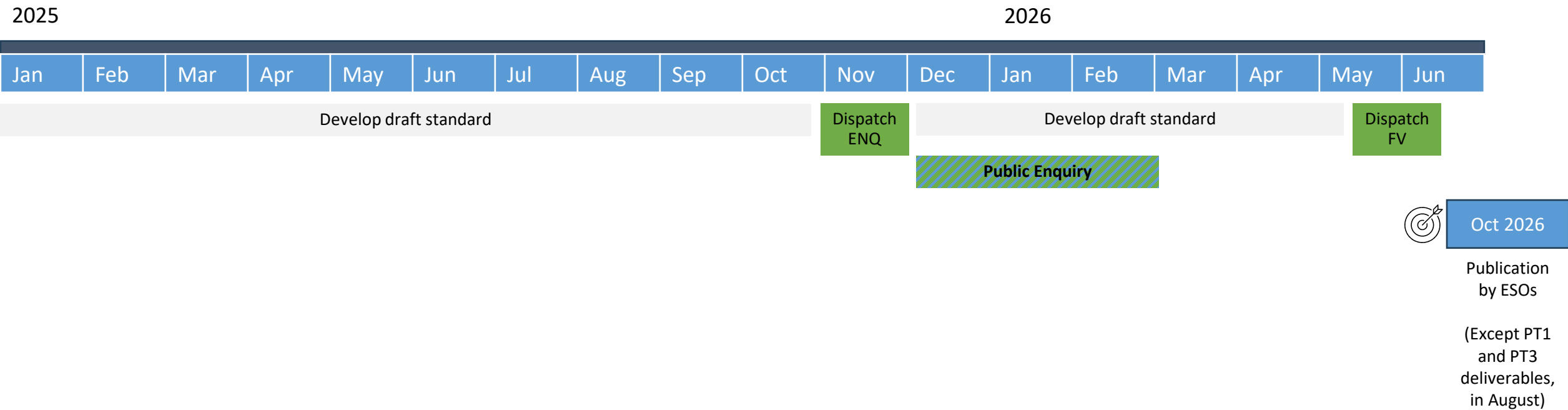
Reference information		Deadline for the adoption by the ESOs
Horizontal standards for security requirements relating to the properties of products with digital elements		
1.	European standard(s) on designing, developing and producing products with digital elements in such a way that they ensure an appropriate level of cybersecurity based on the risks	30/08/2026
2.	European standard(s) on making products with digital elements available on the market without known exploitable vulnerabilities	30/10/2027
3.	European standard(s) on making products with digital elements available on the market with a secure by default configuration	30/10/2027
4.	European standard(s) on ensuring that vulnerabilities in products with digital elements can be addressed through security updates	30/10/2027
5.	European standard(s) on ensuring protection of products with digital elements from unauthorised access and reporting on possible unauthorised access	30/10/2027
6.	European standard(s) on protecting the confidentiality of data stored, transmitted or otherwise processed by a product with digital elements	30/10/2027
7.	European standard(s) on protecting the	30/10/2027

M/606	Technical Committee(s)		Standard title	Last realized stage	Deadline for adoption
Topics M/606 - Annex I	TC ref.	TC title			
Line 1: European standard(s) on designing, developing and producing products with digital elements in such a way that they ensure an appropriate level of cybersecurity based on the risks					
1	CEN-CLC/ITC 13 WG 9	Cybersecurity and Data Protection	Cybersecurity requirements for products with digital elements — Principles for cyber resilience	10.99 - NWI - New Work Item adopted	2026/08/30
Lines 2-14 - European standard(s) CRA essential requirements					
2 to 14	CEN-CLC/ITC 13 WG 9	Cybersecurity and Data Protection	Cybersecurity requirements for products with digital elements – Generic Security Requirements	10.99 - NWI - New Work Item adopted	2027/10/30
Line 15: European standard(s) on vulnerability handling for products with digital elements					
15	CEN-CLC/ITC 13 WG 9	Cybersecurity and Data Protection	Cybersecurity requirements for products with digital elements – Vulnerability Handling	10.99 - NWI - New Work Item adopted	2026/08/30
Line 16: European standard(s) on essential cybersecurity requirements for identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers					
16	CEN/TC 224 WG 17	Personal identification and related personal devices with secure element, systems, operations and privacy in a multi sectorial environment	Identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers : criteria to fulfill with the essential requirements from regulation 2024/2487 (CRA)	TC decision taken	2026/10/30
Line 17: European standard(s) on essential cybersecurity requirements for standalone and embedded browsers					
17a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	European standard(s) on essential cybersecurity requirements for embedded browsers	PWI - Proposed Work Item created	2026/10/30
17b	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	European standard(s) on essential cybersecurity requirements for standalone browsers	PWI - Proposed Work Item created	2026/10/30
Line 18: European standard(s) on essential cybersecurity requirements for password managers					
18	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	European standard(s) on essential cybersecurity requirements for password managers	PWI - Proposed Work Item created	2026/10/30
Line 19: European standard(s) on essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software					
19	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	European standard(s) on essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software	PWI - Proposed Work Item created	2026/10/30
Line 20: European standard(s) on essential cybersecurity requirements for products with digital elements with the function of virtual private network (VPN)					
20a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	European standard(s) on essential cybersecurity requirements for products with digital elements with the function of virtual private network (VPN)	PWI - Proposed Work Item created	2026/10/30
20b	CLC/TC 65X WG 3	Industrial-process measurement, control and automation	Security Profile for products with digital elements with the function of virtual private network (VPN)	00.60 - PWI - Preliminary Work Item created	2026/10/30
Line 21: European standard(s) on essential cybersecurity requirements for network management systems					
21a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	European standard(s) on essential cybersecurity requirements for network management systems	PWI - Proposed Work Item created	2026/10/30
21b	CLC/TC 65X WG 3	Industrial-process measurement, control and automation	Security Profile for network management systems (based on IEC 62443)	00.60 - PWI - Preliminary Work Item created	2026/10/30
Line 22: European standard(s) on essential cybersecurity requirements for Security information and event management (SIEM) systems					
22a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	European standard(s) on essential cybersecurity requirements for Security information and event management (SIEM) systems	PWI - Proposed Work Item created	2026/10/30
22b	CLC/TC 65X WG 3	Industrial-process measurement, control and automation	Security Profile for security information and event management (SIEM) systems (based on IEC 62443)	00.60 - PWI - Preliminary Work Item created	2026/10/30
Line 23: European standard(s) on essential cybersecurity requirements for boot managers					
23	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	European standard(s) on essential cybersecurity requirements for boot managers	PWI - Proposed Work Item created	2026/10/30

How are standards made?

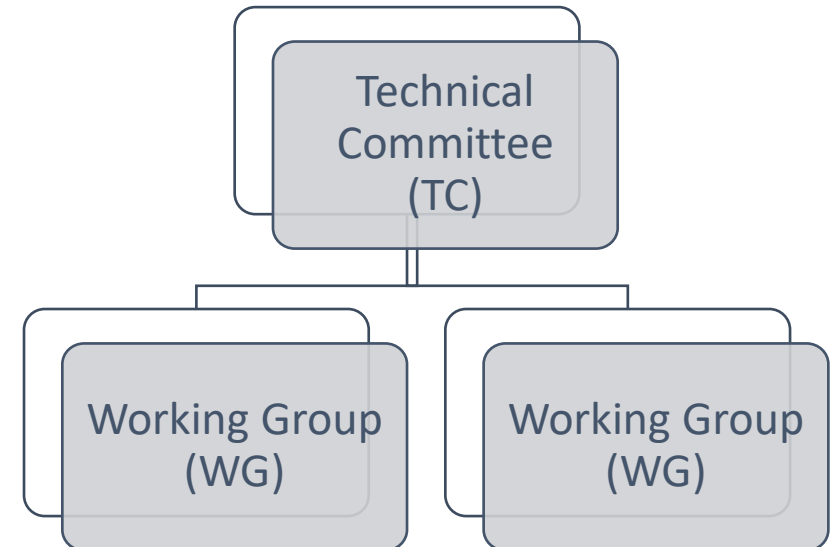


High level expected timeline



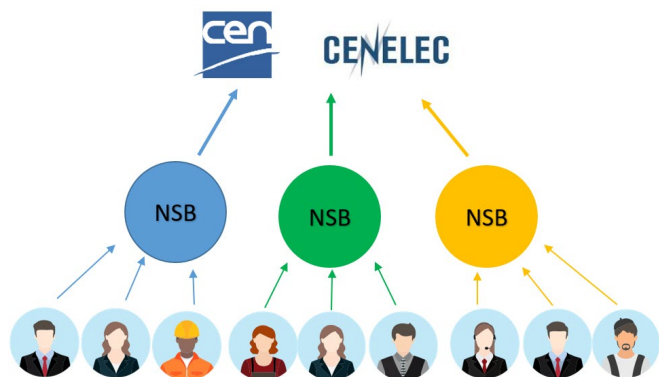
How is the work organized?

- ▶ The standards are developed in Technical Committees (TC)
- ▶ Each TC has Working Groups (WGs)
- ▶ Each WG has a dedicated scope



How to participate?

- CEN and CENELEC Members in 34 countries
- Participation can take place via the national members





Unlocking CRA Security Controls: preparation for UNE Event

8th September 2025

Angelo D'Amato
Founder



Meet your speaker



Angelo D'Amato

Founder / Cybersecurity Expert, Vulnir

Background

- With over fifteen years of experience, he is the subject matter expert for:
 - End-to-end cybersecurity assessments (Penetration testing, Security assessments)
 - Certifications (e.g., UL 2900, Common Criteria)
 - Regulatory compliance (e.g., Radio Equipment Directive, Cyber Resilience Act)
- I currently cover the role of rapporteur (*) for CRA as a CEN contractor within CEN/CLC/JTC 13/WG 9 for
 - PT2: Generic Security Requirements
 - PT3: Vulnerability handling requirements

* The European Union funds my activities within the STAN4CR project through the European Innovation Council and SMEs Executive Agency (EISMEA) under Grant Agreement No. 101196779.

Agenda

- 01 Setting up the context
- 02 CRA's use cases and examples
- 03 Security Controls Framework
- 04 Product-related Essential Requirements overview
- 05 Status and Next Steps
- 06 Preparation / Workshop: Cyber Resilience Act and Horizontal Standards

01

Setting up the context

Preliminary knowledge useful for the workshop



How to learn more?

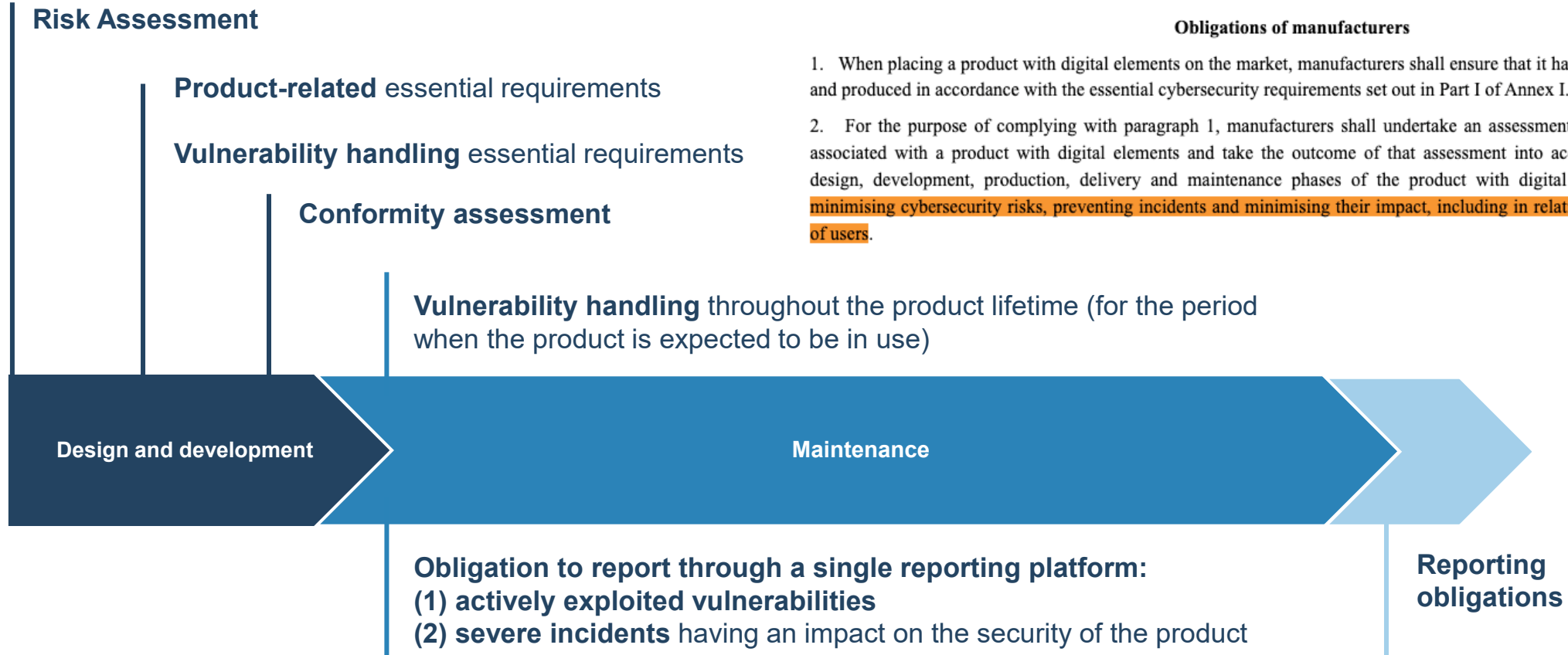
- [Cyber Resilience Act](#): Standardization Request Officially Accepted by CEN, CENELEC, and ETSI
 - Including:
 - CEN, CENELEC and ETSI [Work Programme](#)
 - WG9 convener Ben Kokx – [Youtube Video](#)
- **Core knowledge:**
 - Cyber Resilience Act - Legal Text - [Regulation \(EU\) 2024/2847](#)
 - Make sure that you are familiar with the CRA-related [C\(2025\)618 – Standardisation request M/606](#)
- **To have a better understanding and contextualization:**
 - [New legislative framework](#)
 - The [Blue Guide](#) on the implementation of the product rules 2022
 - Cyber Resilience Act - Impact assessment ([REPORT / STUDY](#) Publication 15 September 2022)

Obligations of manufacturers (CRA)

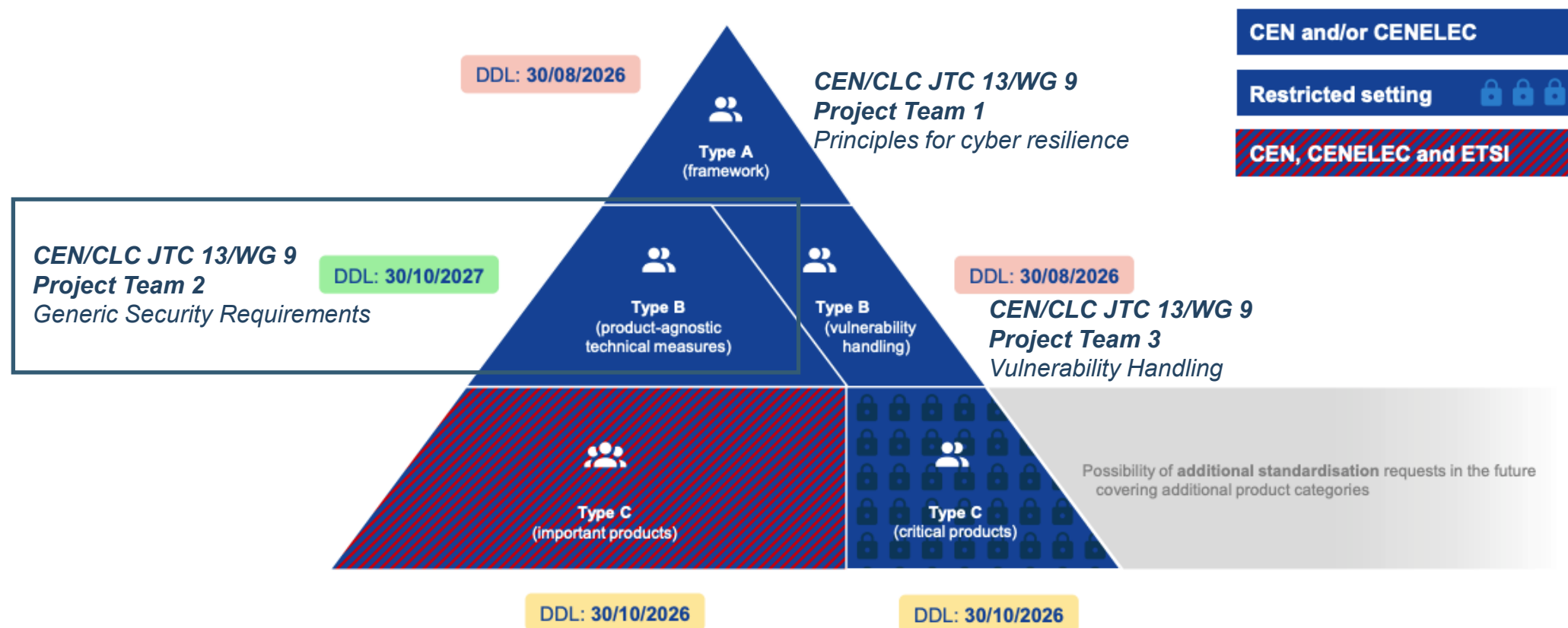
Article 13

Obligations of manufacturers

1. When placing a product with digital elements on the market, manufacturers shall ensure that it has been designed, developed and produced in accordance with the essential cybersecurity requirements set out in Part I of Annex I.
2. For the purpose of complying with paragraph 1, manufacturers shall undertake an assessment of the cybersecurity risks associated with a product with digital elements and take the outcome of that assessment into account during the planning, design, development, production, delivery and maintenance phases of the product with digital elements with a view to **minimising cybersecurity risks, preventing incidents and minimising their impact, including in relation to the health and safety of users.**



CRA standardisation request in a nutshell



ANNEX I

List of new European Standards to be drafted

Reference information		Deadline for the adoption by the ESOs
Horizontal standards for security requirements relating to the properties of products with digital elements		
1.	European standard(s) on designing, developing and producing products with digital elements in such a way that they ensure an appropriate level of cybersecurity based on the risks	30/08/2026
2.	European standard(s) on making products with digital elements available on the market without known exploitable vulnerabilities	30/10/2027
3.	European standard(s) on making products with digital elements available on the market with a secure by default configuration	30/10/2027
4.	European standard(s) on ensuring that vulnerabilities in products with digital elements can be addressed through security updates	30/10/2027
5.	European standard(s) on ensuring protection of products with digital elements from unauthorised access and reporting on possible unauthorised access	30/10/2027
6.	European standard(s) on protecting the confidentiality of data stored, transmitted or otherwise processed by a product with digital elements	30/10/2027
7.	European standard(s) on protecting the integrity of data, commands, programs by a product with digital elements, and its configuration against any manipulation or modification not authorised by the user, as well as reporting on corruptions	30/10/2027
8.	European standard(s) on processing only personal or other data that are adequate,	30/10/2027

OPT1

OPT2

	relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements ('minimisation of data')	
9.	European standard(s) on protecting the availability of essential and basic functions of the product with digital elements	30/10/2027
10.	European standard(s) on minimising the negative impact of a product with digital elements or its connected devices on the availability of services provided by other devices or networks	30/10/2027
11.	European standard(s) on designing, developing and producing products with digital elements with limited attack surfaces	30/10/2027
12.	European standard(s) on designing, developing and producing products with digital elements that reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques	30/10/2027
13.	European standard(s) on providing security related information by recording and/or monitoring relevant internal activity of products with digital elements with an opt-out mechanism for the user	30/10/2027
14.	European standard(s) on securely and easily removing or transferring all data and settings of a product with digital elements.	30/10/2027
Horizontal standards for vulnerability handling requirements		
15.	European standard(s) on vulnerability handling for products with digital elements	30/08/2026

OPT3

Interplay between the three deliverables



For discussion purposes only
DRAFT

Project 1

High level process **activities** to address the Total Product Life Cycle, defining:

- Goal that needs to be achieved
- Mandatory and optional inputs
- Minimum expected outcomes



During risk assessment the appropriate security controls and their appropriate level can be selected to ensure risks are mitigated to an acceptable level

Risk assessment

Elicit requirements

Process activities such as security monitoring, risk assessment, verification, validation and release

Project 3

More detailed process **activities** (with assessment criteria fit for a presumption of conformity) to address the vulnerability management requirements

Project 2

A mapping of the essential product requirements to a list of appropriate **security controls** at various levels (controls have their own scale/levels to achieve the goal of the security control)

During the elicit requirements activity the deliverables from project 2 can be used to determine and select the appropriate security controls that should be implemented into the product to fulfil on a risk-based manner the essential requirements

Main objectives of the deliverables

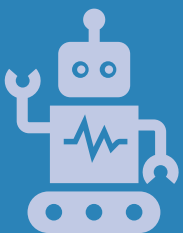


CENELEC

For discussion purposes only
DRAFT

PT1: Principles for cyber resilience

- Covers CRA Annex I, Part 1, Requirement 1
- **Process** standard to ensure products are developed and maintained with a risk-based approach to cover **any** security risks (as a catch-all, as 2a-m do not cover all possible cybersecurity risks)
- Implementation demonstrated via documented process outputs



PT2: Generic security requirements

- Covers CRA Annex I, Part 1, Requirement 2 (a-m)
- **Product** standard addressing a specific set of security requirements by mapping security objectives to a catalog of possible security controls
- Implementation demonstrated via the product itself and/or supported by technical documentation



PT3: Vulnerability handling

- Covers CRA Annex I, Part 2
- **Process** standard to ensure products are maintained in a secure state using a risk-based approach
- Implementation demonstrated via documented process outputs and actions in the market (updates, notifications, recalls, etc.)

Role of harmonised standards



Manufacturer

Can use it to demonstrate that their products meet the necessary requirements, thus facilitating market access.

Notified Bodies

Can use it to execute conformity assessment activities and verify the due diligence of the manufacturers that requested their services.

Harmonised standard: translates the legal requirement (what) to detailed technical requirements (how)

Can be used to verify consistently the implementation of an essential requirement

Market Surveillance

02

CRA

Use cases and examples



My Friend Cayla

- My Friend Cayla is made by Genesis Toys and distributed in Europe by Vivid Toy Group.
- The doll was named 2014 Innovative Toy of the Year by the London Toy Industry Association.
- The first vulnerability was disclosed in January 2015.
- In February 2017, the German Federal Network Agency (Bundesnetzagentur) had to invoke a federal law against espionage devices to ban a connected toy that intentionally transferred recordings outside the EU.



Issues and ESR violations

- **Lack of safety:** It was possible to talk and listen through the toy without requiring physical access to it. The problem stemmed from the design of the pairing.
 - Secure by default configuration
 - Authorized access
- **Illegal user terms:** The dolls could record and collect the private conversations of young children without any limitations on collection, use, or disclosure of this personal information.
- **Kids' secrets are shared:** Anything the child tells the doll is transferred to the U.S.-based company Nuance Communications, which specializes in speech recognition technologies.
- **Kids are subject to hidden marketing:** The toys are embedded with pre-programmed phrases that endorse different commercial products. For example, Cayla will happily talk about how much she loves different Disney movies; meanwhile, the app provider has a commercial relationship with Disney.
 - Data minimization

Role of essential requirements



Mirai IoT Botnet, Aug 2016

- The first ever botnet of Internet of Things devices
- **Root causes:**
 - Weak default configuration (default password)
- **Effect:**
 - High-profile websites and services that relied on Dyn for DNS resolution, including Twitter, Reddit, Netflix, Airbnb, Amazon were disrupted
- **Highlighted the importance of:**
 - Secure by default configuration

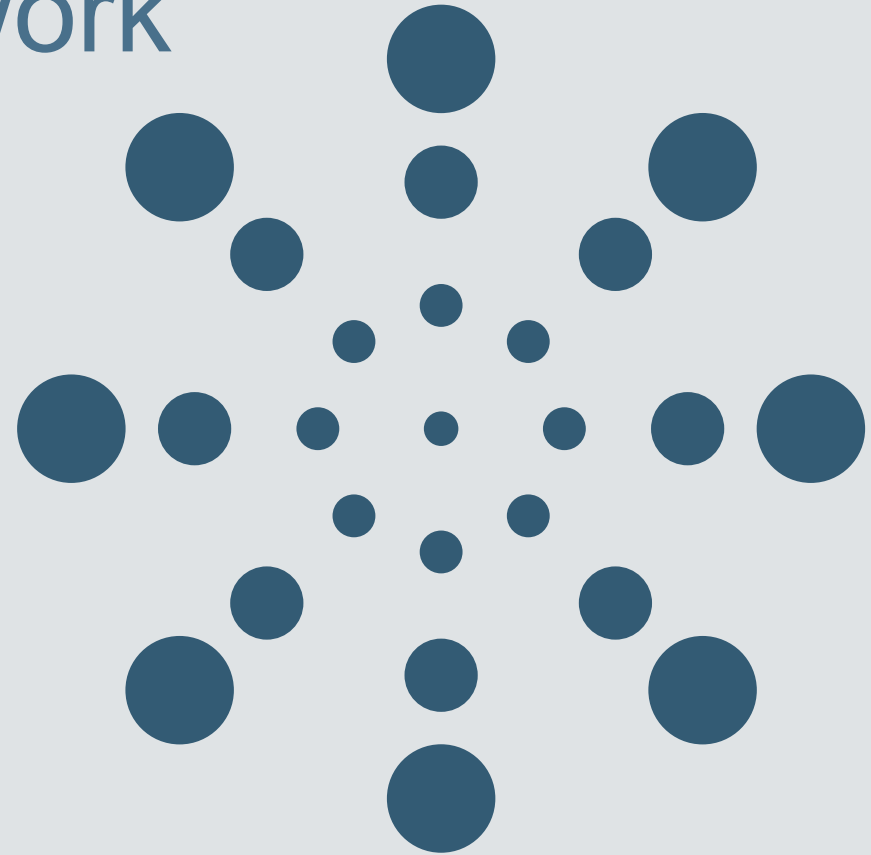
Log4j (Log4Shell), Dec 2021

- The first ever botnet of Internet of Things devices
- **Root cause:**
 - JNDI lookups within log messages without sufficient validation or sanitization
- **Effect:**
 - Its impact stemmed from the ubiquitous nature of the vulnerable Log4j library and the severe nature of the vulnerability itself (Remote Code Execution).
- **Highlighted the importance of:**
 - Security updates / SBOM

03

Security Controls Framework

Prepare

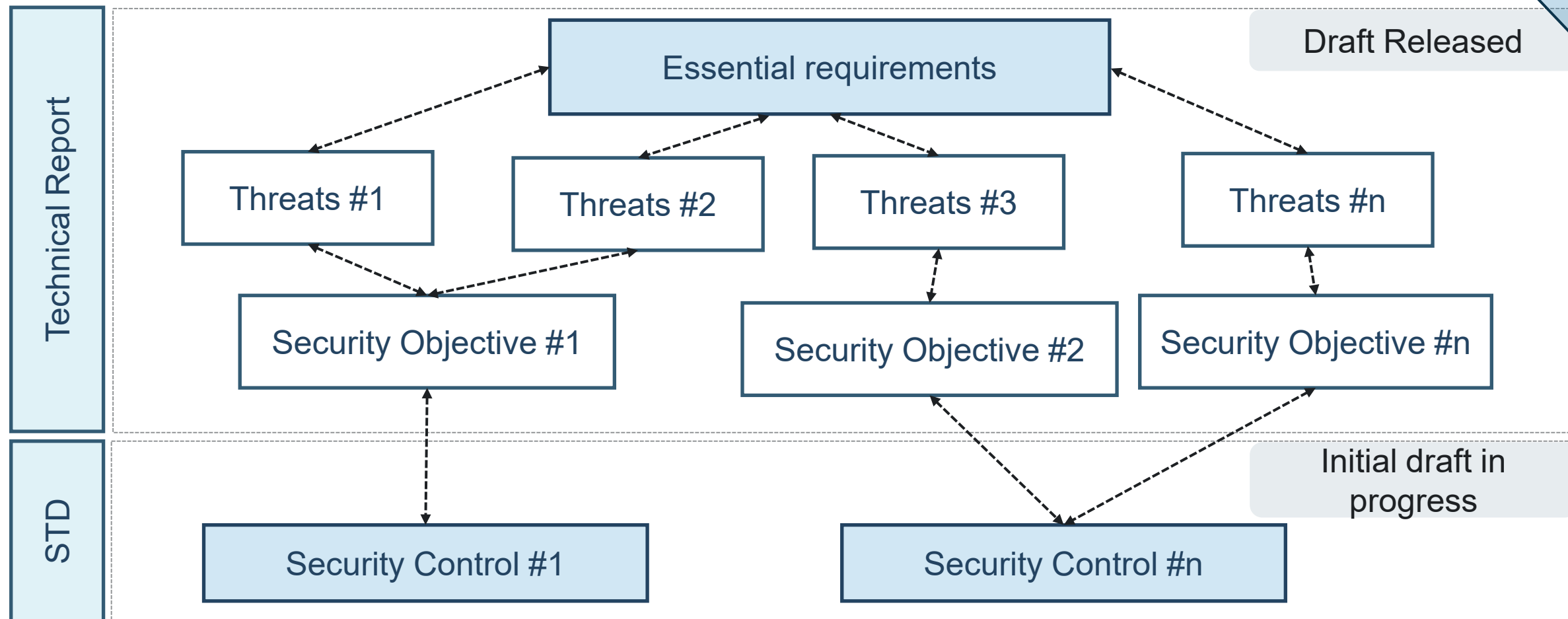


PT2 Objectives

- ☐ CRA requirement Annex I, Part I
- ☐ Standardization request M/606 Annex I part II, the 2-14th (see also CEN, CENELEC and ETSI Work Programme) to be published by 30/10/2027.
- ☐ Could be a guide for vertical standards and used as a reference
- ☐ Guide economic operators for products that fall into the default category
- ☐ Provides a library of security controls with their objectives and more technical assessment criteria
- ☐ Builds upon the EN 18031:2024 series, augmented with additional security controls
- ☐ Provides a mapping of the essential requirements to these security controls
- ☐ It will include at least provisions related to the
 - ☐ Security problem definition
 - ☐ Security objectives
 - ☐ Technical specification of security requirements,
 - ☐ Assessment methodology.

PT2 Artifacts

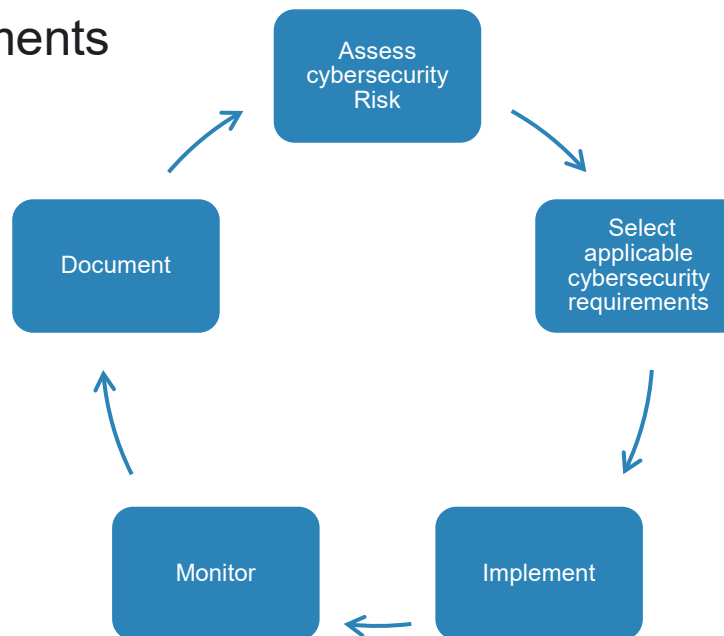
DRAFT
For discussion purposes only



ISMS

ISO 27001 is a security standard that helps protect information assets by establishing an information security management system

- Identifying information security requirements
- Assessing information security risks
- Treating information security risks
- Selecting and implementing controls
- Monitor, maintain, and improve the effectiveness of the ISMS
- Continual improvement



INTERNATIONAL
STANDARD

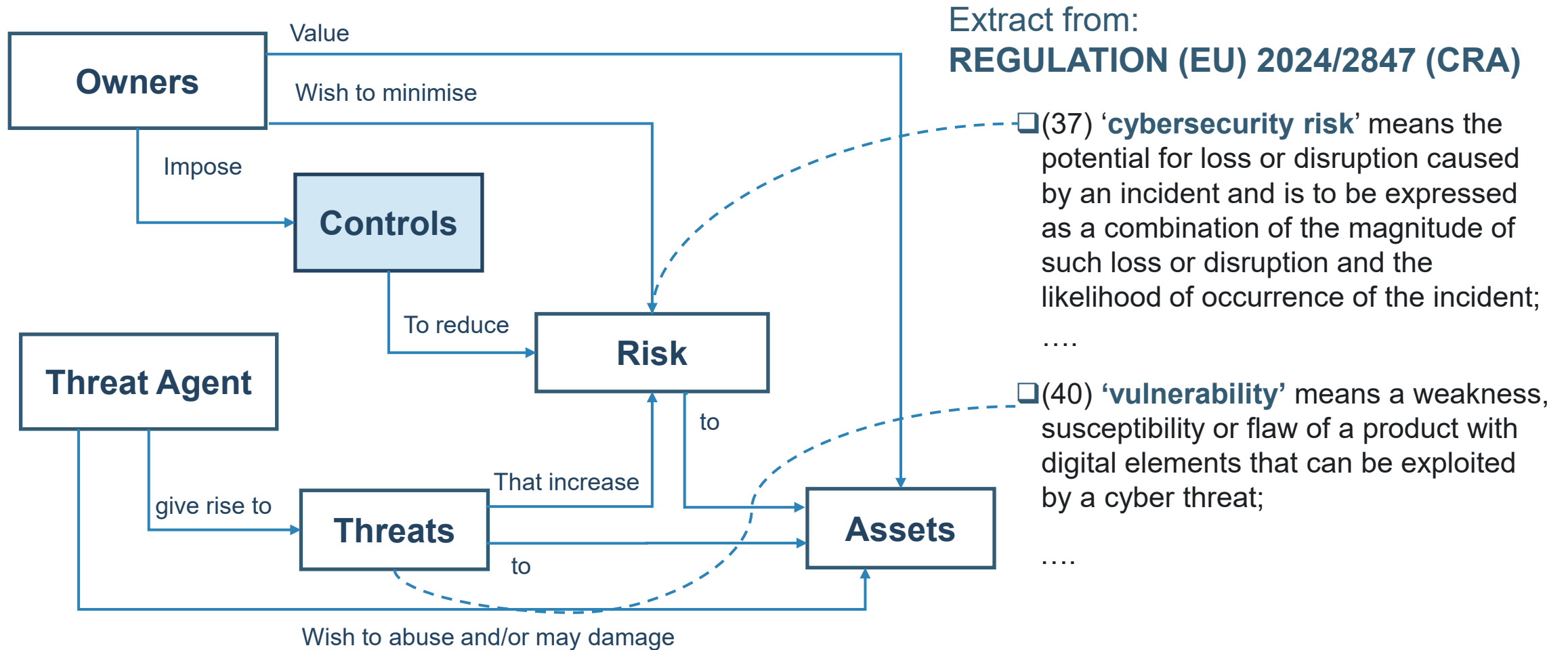
ISO/IEC
27001

Third edition
2022-10

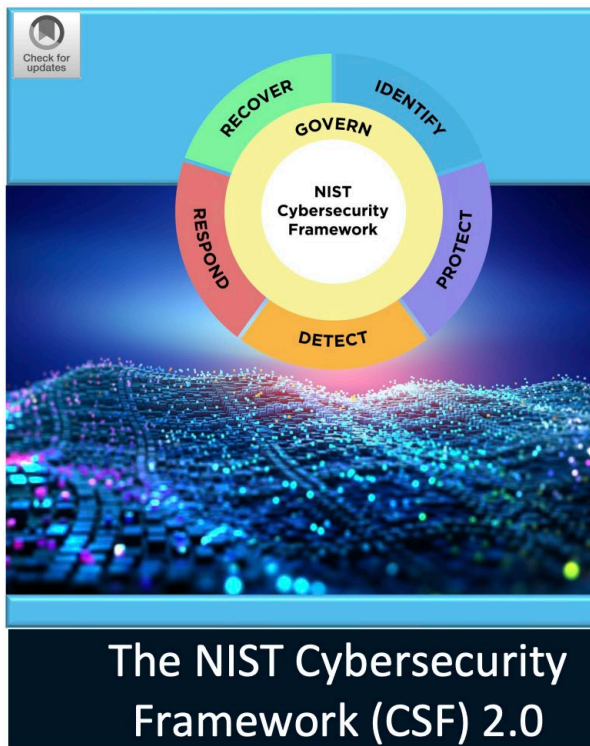
Information security, cybersecurity and privacy protection — Information security management systems — Requirements

Sécurité de l'information, cybersécurité et protection de la vie privée — Systèmes de management de la sécurité de l'information — Exigences

Security concepts and relationships



Example of security frameworks



The NIST Cybersecurity Framework (CSF) 2.0

National Institute of Standards and Technology
This publication is available free of charge from: <https://doi.org/10.6028/NIST.CSWP.29>
February 26, 2024

NIST NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY
U.S. DEPARTMENT OF COMMERCE



CyberFundamentals ESSENTIAL

Version: 01.03.2023

Centre for Cybersecurity
Under the authority of the Prime Minister



CIS Critical Security Controls® Version 8

V8

Third edition
2022-02

Corrected version
2022-03

Information security, cybersecurity and privacy protection — Information security controls

Sécurité de l'information, cybersécurité et protection de la vie privée — Mesures de sécurité de l'information

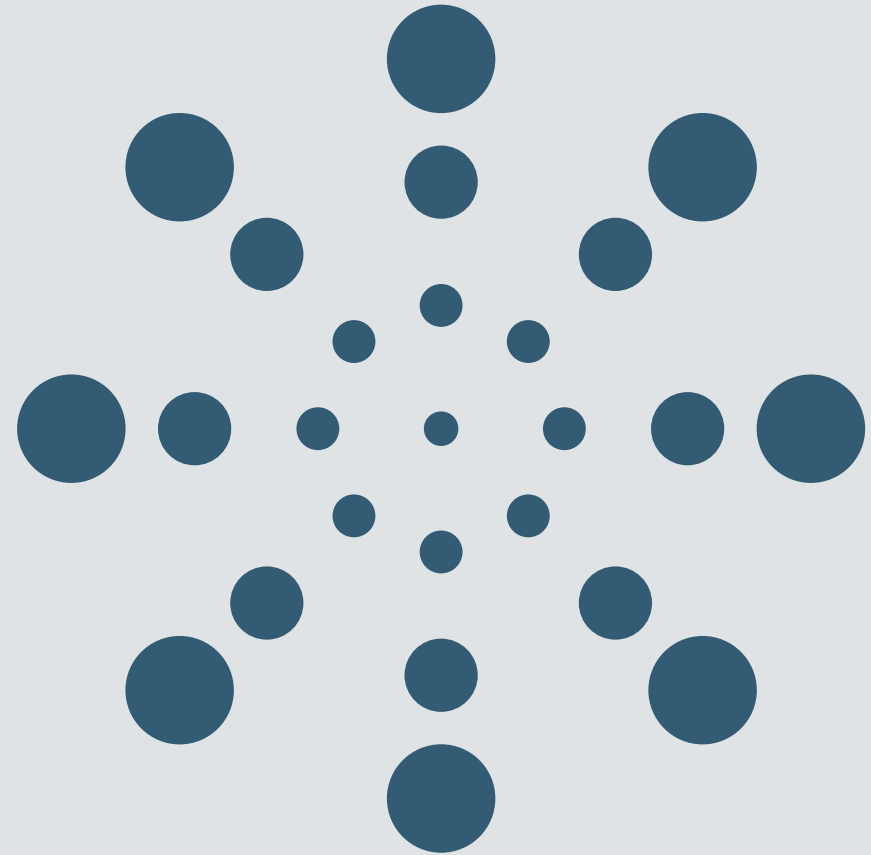


Reference number
ISO/IEC 27002:2022(E)

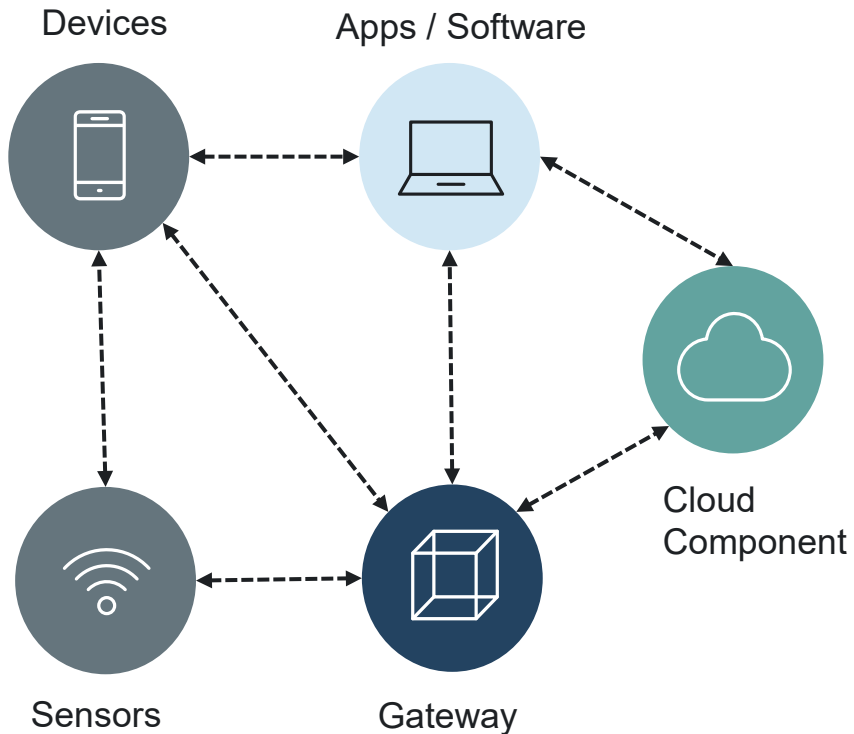
© ISO/IEC 2022

Essential Requirements

Understanding of the essential requirements and relevant implications



Overview of the CRA's Essential Requirements



(1) **‘product with digital elements’** means a software or hardware product and its remote data processing solutions, including software or hardware components being placed on the market separately;

❑ Ensure that products with digital elements hardware and software placed on the EU market have fewer cybersecurity vulnerabilities.

❑ **Better protection** for consumers, supply chains, organisations, businesses, and IT Infrastructure

▪ Secure by Design / Risk Assessment

- No known exploitable vulnerabilities
- Secure by default configuration
- Security updates
- Authorized access
- Confidentiality protection
- Integrity protection
- Data minimization
- Availability protection
- Minimize negative impact
- Attack surface minimization
- Reduce the impact of an incident
- Logging and monitoring controls
- Secure deletion mechanisms

▪ Vulnerability Handling Requirements

Essential Requirements ANNEX I PART II

Vulnerability Handling

accessible action address advisory agreed applicable
apply available components contained
coordinated delay digital document
elements ensure facilitate
fixed format given helping identify
including information issues machine-readable
manner manufacturers measures
mechanisms otherwise possibility potential
product providing
public relation relevant remediate reporting
risks security severity share software
taken technically updates users
vulnerabilities

❑ Ensure that products with digital elements hardware and software placed on the EU market have fewer cybersecurity vulnerabilities.

❑ **Better protection** for consumers, supply chains, organisations, businesses, and IT Infrastructure

▪ Secure by Design / Risk Assessment

▪ Vulnerability Handling Requirements

- Identify vulnerabilities / SBOM
- Remediate vulnerabilities
- Regular test
- Inform on fixed vulnerabilities
- CVD Policy in place
- Intake of potential vulnerabilities
- Secure distribution of updates
- Update available and related dissemination

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (a) - Vulnerability Assessment

- (a) be made available on the market without known exploitable vulnerabilities;

Threat

Security Objective

Threat.KnownVulnerabilityExploitation

SO.VulnerabilityManagementProcess

Mapping with 18031-X:2024

[GEC] General equipment capabilities

- [GEC-1] Up-to-date software and hardware with no publicly known exploitable vulnerabilities

ADDED SECURITY CONTROLS

NO ADDITION

Note:

- It is important to consider the process part (Vulnerability management activities) PT1/PT3
 - Test for known vulnerabilities
 - Regular tests that involves as minimum known vulnerabilities testing / vulnerability assessment
- Do we need a control/activity called **Known vulnerability assessment** with a focus on prioritizing weaknesses that are exploitable
- Considering if to include - **Threat.SupplyChainVulnerabilityExploitation**

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (b) - Secure Configuration

(b) be made available on the market with a **secure by default configuration**, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the **possibility to reset the product to its original state**;

Threat	Security Objective
Threat.UnsecureDefaultConfigExploitation	SO.SecureDefaultConfiguration
	SO.SecureStartupConfig
Threat.MissingResetFunctionalityConfigExploitation	SO.FactoryReset
Threat.MissingResetFunctionalityMalwareExploitation	
Threat.MissingResetFunctionalityDataExtraction	

Note:

- “Secure-by-Default” means products are resilient against prevalent exploitation techniques out of the box without additional charge. Software should start in a secure state without requiring extensive user configuration, ensuring the default settings are always the most secure option
 - OWASP Top 10 Proactive Controls - [C5: Secure By Default Configurations](#)
 - SA-8(23): Secure Defaults
- Eg. Deactivate insecure protocols / no default passwords / least privilege / automatic updates

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (b) - Secure Configuration

(b) be made available on the market with a **secure by default configuration**, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the **possibility to reset the product to its original state**;

Mapping with 18031-X:2024

NO MAPPING

ADDED SECURITY CONTROLS

[GEC] General Equipment Capabilities

- [GEC-8] Secure default configuration
- [GEC-9] Secure startup configuration
- [GEC-10] Factory Reset

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (c) - Security Updates

(c) ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them;

Threat	Security Objective
Threat.UnpatchableVulnerabilityExploitation	SO.Updateability SO.AvailabilityOfUpdates:
Threat.UnpatchedVulnerabilityExploitation	SOAutomaticUpdates SO.TimelyUpdates
Threat.MissingUpdateNotificationExploitation:	SO.UserUpdateNotification

Note/Challenge:

- The challenge is about the Remote Data Processing – could happen that manufacturers are using a silent patching approach for the “cloud component” side.
- How to deal with appropriate timeline and timely updates

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (c) - Security Updates

(c) ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them;

Mapping with 18031-X:2024

[SUM] Secure update mechanism

- [SUM-1] Applicability of update mechanisms
- [SUM-2] Secure updates
- [SUM-3] Automated updates

ADDED SECURITY CONTROLS

[SUM] Secure update mechanism

- [SUM-4] Availability of updates [SSU-2]
- [SUM-5] Update Mechanism [SSU-3]
- [SUM-6] Timely Updates [SSU-5]
- [SUM-7] User Update Notifications [SSU-6]
- [SUM-8] Postponed Updates [SSU-7]

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (d) - Access Control

(d) ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access;

Threat	Security Objective
Threat.UnauthorizedAccess	SO.AccessControl
Threat.NotReportedUnauthorizedAccess	SO.AccessControlReport

Note:

- Missing control: additional **access control reporting**
 - (report on possible unauthorised access)

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (d) - Access Control

(d) ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access;

Mapping with 18031-X:2024

[ACM] Access control mechanism

- [ACM-1] Applicability of access control mechanisms
- [ACM-2] Appropriate access control mechanisms

Mapping with 18031-X:2024

[AUM] Authentication mechanism

- [AUM-1] Applicability of authentication mechanisms
 - [AUM-1-1] Requirement network interface
 - [AUM-1-2] Requirement user interface
- [AUM-2] Appropriate authentication mechanisms
- [AUM-3] Authenticator validation
- [AUM-4] Changing authenticators
- [AUM-5] Password strength
 - [AUM-5-1] Requirement for factory default passwords
 - [AUM-5-2] Requirement for non-factory default passwords
- [AUM-6] Brute force protection

ADDED SECURITY CONTROLS

NO ADDITION

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (e) - Confidentiality (Disclosure)

(e) protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means;

Threat	Security Objective
Threat.DataAtRestDisclosure	SO.DataStoredConfidentiality
Threat.DataProcessedDataDisclosure	SO.DataProcessedConfidentiality
Threat.DataInTransitDisclosure	SO.DataTransmittedConfidentiality

Note:

- Missing control: requirements for protecting data in transit and processed

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (e) - Confidentiality (Disclosure)

(e) protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means;

Mapping with 18031-X:2024

[SSM] Secure storage mechanism

- [SSM-1] Applicability of secure storage mechanisms
- [SSM-3] Appropriate confidentiality protection for secure storage mechanisms

[SCM] Secure communication mechanism

- [SCM-3] Secure communication mechanisms with confidentiality protection
- [SCM-4] Appropriate replay protection for secure communication mechanisms

[CCK] Confidential cryptographic keys

- [CCK-1] Appropriate CCKs
- [CCK-2] CCK generation mechanisms
- [CCK-3] Preventing static default values for preinstalled CCKs

[CRY] Cryptography

- [CRY-1] Best practice cryptography

ADDED SECURITY CONTROLS

NO ADDITION

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (f) - Integrity (Tampering)

(f) protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions;

Threat	Security Objective
Threat.DataAtRestTampering	SO.DataStoredIntegrity
Threat.DataInTransitTampering	SO.DataTransmittedIntegrity SO.ComAuth
Threat.ProcessedDataTampering	SO.DataProcessedIntegrity
Threat.TamperingUndetected	SO.IntegrityReport

Note:

- Missing control: requirements for protecting data processed

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (f) - Integrity (Tampering)

(f) protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions;

Mapping with 18031-X:2024

[SSM] Secure storage mechanism

- [SSM-1] Applicability of secure storage mechanisms
- [SSM-2] Appropriate integrity protection for secure storage mechanisms

[SCM] Secure communication mechanism

- [SCM-2] Secure communication mechanisms with integrity protection
- [SCM-2a] Secure communication mechanisms with authenticity protection

ADDED SECURITY CONTROLS

NO ADDITION

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (g) - Data Minimization

(g) process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation);

Threat	Security Objective
Threat.UnnecessaryDataMisuse	SO.DataMinimization

Note:

- Still in definition phase and considering how to make it as a technical requirement and related to the capabilities of the products.
- It is clear that to minimize data relevant to support a functionality of specific use there should be a strong data classification process

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (g) - Data Minimization

(g) process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation);

Mapping with 18031-X:2024

[UNM] User notification mechanism

- [UNM-1] Applicability of user notification mechanisms
- [UNM-2] Appropriate user notification content

ADDED SECURITY CONTROLS

[DTM] Data minimization

- [DTM-1] Data minimization

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (h) - Availability

(h) protect the **availability** of essential and basic functions, also after an **incident**, including through **resilience** and mitigation measures against **denial-of-service attacks**;

Threat	Security Objective
Threat.LongTermAvailabilityDegradation	SO.IncidentRecovery
Threat.ShortTermAvailabilityDegradation	SO.IncidentResilience

Note:

- This requirement may be address by asking to the manufacturers to document the essential and basic functions and to define the related security controls
- Define and verity the fault tollerant mechanisms implemented from a product pererspective if applicable

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (h) - Availability

(h) protect the **availability** of essential and basic functions, also after an **incident**, including through **resilience** and mitigation measures against **denial-of-service attacks**;

Mapping with 18031-X:2024

[RLM] Resilience mechanism

- [RLM-1] Applicability and appropriateness of resilience mechanisms

ADDED SECURITY CONTROLS

[RLM] Resilience mechanism

- [RLM-2] Resilience - Recovery from incidents

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (i) - External Impact

(i) minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks;

Threat	Security Objective
Threat.ExtServiceAvailabilityDegradation	SO.LimitExternalImpact SO.PreventAttackPropagation

Note:

- Still in definition phase in how to details this requirement from a product capability perspective

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (i) - External Impact

(i) minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks;

Mapping with 18031-X:2024

[GEC] General equipment capabilities

- [GEC-8] Equipment Integrity

ADDED SECURITY CONTROLS

[LIM] External impact limitation

- [LIM-1] External impact limitation
- [LIM-2] Prevention of attack propagation

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (j) - Attack Surface Minimization

(j) be designed, developed and produced to **limit attack surfaces**, including external interfaces;

Threat	Security Objective
Threat.UnnecessaryFunctionalityExploitation	SO.ReduceAttackSurface

Note:

- Still in definition phase but for sure we will include
 - hardening mechanisms
 - Documentation
 - Input verification

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (j) - Attack Surface Minimization

(j) be designed, developed and produced to **limit attack surfaces**, including external interfaces;

Mapping with 18031-X:2024

[GEC] General equipment capabilities

- [GEC-2] Limit exposure of services via related network interfaces
- [GEC-3] Configuration of optional services and the related exposed network interfaces
- [GEC-4] Documentation of exposed network interfaces and exposed services via network interfaces
- [GEC-5] No unnecessary external interfaces
- [GEC-6] Input validation
- [GEC-7] Documentation of external sensing capabilities

ADDED SECURITY CONTROLS

[GEC] General equipment capabilities

- [GEC-11] Reduction of the attack surface

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (k) - Impact of Incident

(k) be designed, developed and produced to **reduce the impact of an incident** using appropriate exploitation mitigation mechanisms and techniques;

Threat	Security Objective
Threat.ExploitationMitigationFailure	SO.ReduceImpactOfIncident

Note:

- Still in definition phase: this requirement is clearly a process driven requirement but we will focus also in this case on the product capabilities and exploitation mitigation mechanisms and techniques. There is an overlap that need to be still formalize with the minimize negative impact

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (k) - Impact of Incident

(k) be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques;

Mapping with 18031-X:2024

NO MAPPING

ADDED SECURITY CONTROLS

[GEC] General equipment capabilities

- [GEC-12] Reduction of the impact of an incident

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (I) - Monitoring and Logging

(I) provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user;

Threat	Security Objective
Threat.SecurityActivitiesNotMonitoredRecorded	SO.DetectionOfSecurityRelevantActivities SO.InfoAboutSecurityRelevantActivities
Threat.MonitoringDataDisclosure	SO.OptionDisableDataMonitoring

Note:

- Still in definition phase

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (I) - Monitoring and Logging

(I) provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user;

Mapping with 18031-X:2024

[LGM] Logging mechanism

- [LGM-1] Applicability of logging mechanisms
- [LGM-2] Persistent storage of log data
- [LGM-3] Minimum number of persistently stored events
- [LGM-4] Time-related information of persistently stored dog data

[NMM] Network monitoring mechanism

- [NMM-1] Applicability and appropriateness of network monitoring mechanisms

[TCM] Traffic control mechanism

- [TCM-1] Applicability of and appropriate traffic control mechanisms

ADDED SECURITY CONTROLS

[MON] Recording and monitoring of security activities

- [MON-1] Recording and monitoring of security activities

[LGM] Logging mechanism

- [LGM-5] Recording and monitoring of security activities
- [LGM-6] Monitoring of security relevant activities
- [LGM-7] Providing information about monitored activities
- [LGM-8] Disabling monitoring

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (m) - Data Deletion

(m) provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner.

Threat	Security Objective
Threat.DeletedDataDisclosure	SO.SecureDataDeletion
Threat.MissingDataRemovalExploitation	SO.SecureDisposalByUser
Threat.DataInTransitDisclosure	SO.SecureComConfidentiality SO.ComAuth
Threat.DataInTransitTampering:	SO.SecureComIntegrity: SO.ComAuth:

Note/challenges:

- How to take in consideration the data deletion for data in transit – this can be done on a communication level (SCM)
- Having a SO.ComAuth may be redundant or not contextualize for data deletion but of course you expect that only the authorized entity could execute this function

Vulnerability Assessment

Secure Configuration

Security updates

Authorized access

Confidentiality

Integrity

Data minimization

Availability

Minimize negative impact

Attack surface minimization

Incident impact reduction

Logging and monitoring

Secure deletion

ECR ANNEX I Part I (2) (m) - Data Deletion

(m) provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner.

Mapping with 18031-X:2024

[DLM] Deletion mechanism

- [DLM-1] Applicability of deletion mechanisms

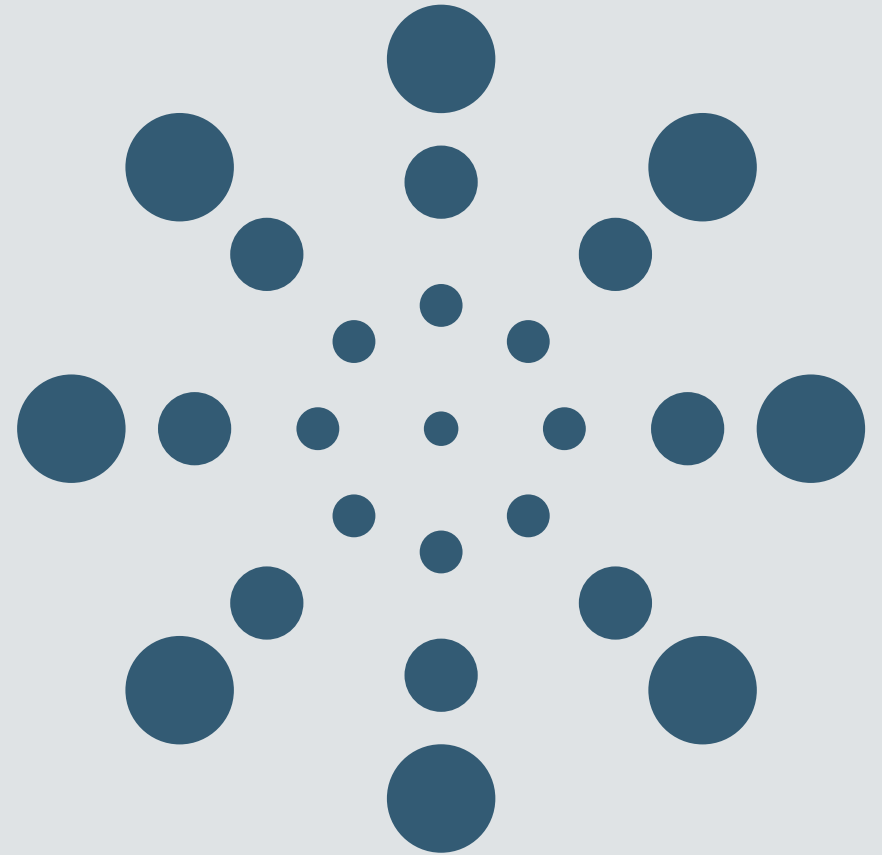
ADDED SECURITY CONTROLS

[DLM] Deletion mechanism

- [DLM-2] Secure data deletion
- [DLM-3] Secure disposal by the user [DEL-1]
- [DLM-4] Confidential export of deleted data
- [DLM-5] Authenticity of the communication partner for export of deleted data
- [DLM-6] Protection against leaking meta information
- [DLM-7] Integrity protected export of deleted data

Status and Next Steps

Status and next steps



Some references

- **ENISA**

- EUCC SCHEME GUIDELINES ON VULNERABILITY MANAGEMENT AND DISCLOSURE, Version 1.1, January 2025
- Vulnerability disclosure
 - <https://www.enisa.europa.eu/topics/vulnerability-disclosure>

- **IoT Security Foundation**

- Vulnerability Disclosure, Best Practice Guidelines, Release 2.0, September 2021

- **FIRST**

- Guidelines and Practices for Multi-Party Vulnerability Coordination and Disclosure, Spring 2020
- PSIRT Services Framework

- **NIST**

- Vulnerability Disclosure Guidelines
 - <https://csrc.nist.gov/Projects/vulnerability-disclosure-guidelines>

- **ETSI**

- ETSI TR 103 838 V1.1.1 (2022-01) Cyber Security; Guide to Coordinated Vulnerability Disclosure
- ETSI TR 104 003 V1.1.1 (2024-09) The vulnerability disclosure ecosystem

- **ISO/IEC**

- ISO/IEC TR 5895:2022 - Cybersecurity — Multi-party coordinated vulnerability disclosure and handling
- ISO/IEC 30111:2019 - Information technology — Security techniques — Vulnerability handling processes
- ISO/IEC 29147:2018 - Information technology — Security techniques — Vulnerability disclosure
- ISO/IEC 18974:2023 - Information technology — OpenChain security assurance specification

- **IoT Security Foundation**

- The State of Vulnerability Disclosure Policy (VDP) Usage in Global Consumer IoT in 2024 (25th November 2024)

- **Google**

- Guide to coordinated vulnerability disclosure for open-source projects (<https://github.com/google/oss-vulnerability-guide/tree/main>)

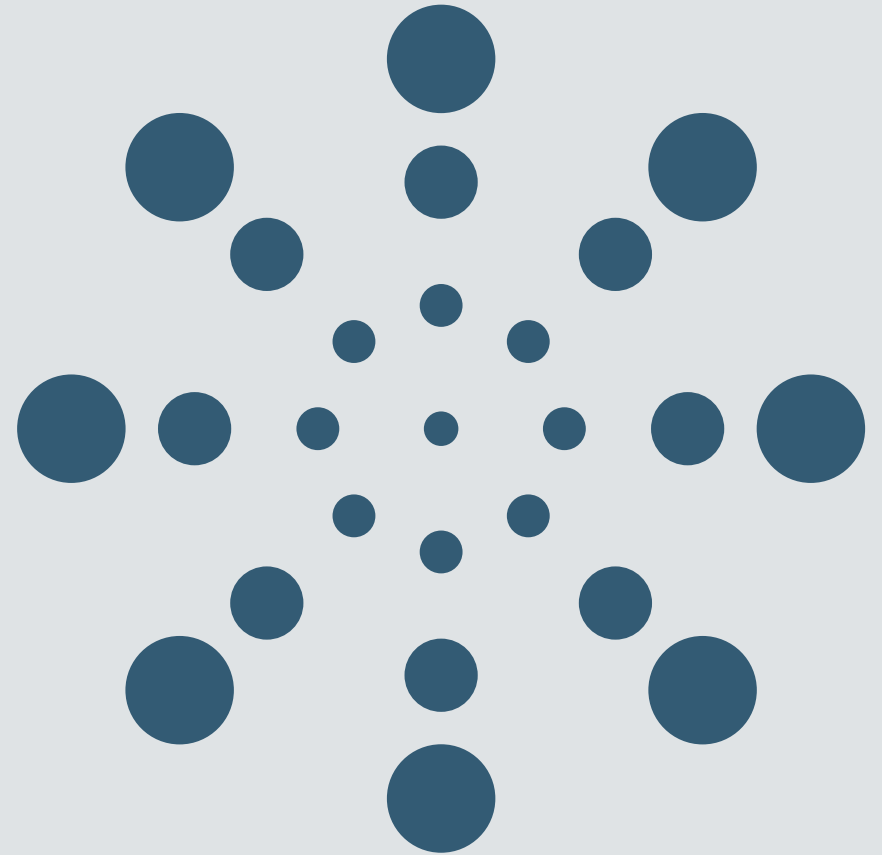
Example standards with affinities with PT2 standard

- Information Security Management
 - ISO/IEC 27001, ISO/IEC 27002
- Product and System Specific Security Requirements
 - ETSI EN 303 645
 - EN IEC 62443-4-2
 - EN 18031-1, EN 18031-2, EN 18031-3
- Security Evaluation and Testing
 - ISO/IEC 18045
 - EN 17640
- IoT Specifics (Architecture and Overarching Security)
 - ISO/IEC 30141
 - ISO/IEC 27400
- Privacy assurance
 - ETSI TS 103 485
- Security Throughout the Product Lifecycle
 - ISO/IEC TR 6114

Next Steps

- We developed an initial Technical Report that links essential requirements, threats, and security objectives.
 - Validate the TR and identify any missing threats, given the horizontal nature of the PT2 standard.
 - An instantiation with a reference architecture and demonstrate the allocation of threats and their corresponding security controls, aligned with essential requirements from the CRA.
 - Propose a characterization of security controls and allocate to a use case (eg, IP camera, smart washing machine, or other)
- The PT2 standard is still in an early stage.
 - Bring to the table case studies and examples that we should consider when defining the security requirements and potential exceptions, if any.
 - Perspectives to support the definition of appropriate evaluation methodology for security controls
- For when we have a more complete PT2 draft.
 - It would be interesting to have a pilot evaluation of security controls for a use case (eg, IP camera, smart washing machine, or other)

Preparation / Workshop: Cyber Resilience Act and Horizontal Standards





Evento

Workshop: Cyber Resilience Act and Horizontal Standards

26/06/2025

Key information

Date: September 23, 2025

Time: 9:30 AM – 5:00 PM

Format: Hybrid. Hotel NH Ventas (C/ de Biarritz, 2. Madrid)

Language: English

[Register \(75-100 participants in-person, unlimited online\) >](#)[Agenda >](#)[Visiting MADRID >](#)

The **Cyber Resilience Act and Horizontal Standards Workshop** is a unique opportunity to gain insights into the **key elements of the Cyber Resilience Act (CRA)** and to **participate in discussions with other experts** to influence the future of cybersecurity and resilience in Europe through the horizontal standards that are developed to support the CRA.

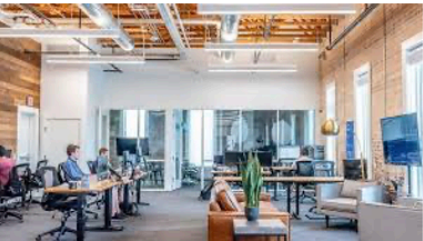
The Cyber Resilience Act (CRA) aims to enhance **EU cybersecurity** by ensuring that digital products and services remain secure throughout their lifecycle. It promotes proactive risk management and accountability, enabling businesses and users to collaborate, building a safer digital future. To support CRA implementation, the European Commission has issued a standardization request to the European Standardization Organizations, focusing on both horizontal standards for a generic framework and vertical standards for specific product risks. This workshop will highlight the **work on the horizontal standards required for CRA compliance**.

The workshop will give an **overview of the Cyber Resilience Act**, highlighting the key role of standardization and the way forward. The workshop will provide a comprehensive understanding of how standards can effectively mitigate risks, enhance cybersecurity posture, and ensure that products and services are aligned with the legal expectations set forth by the CRA.

Workshop Scenarios

SCENARIO 1 - CURRENT PRODUCT INTENDED ENVIROMENT

A **time switch** installed in office buildings is used to **control heating or air conditioning systems** based on programmed schedules to optimize energy consumption and comfort.



SCENARIO 2 - CRITICAL SCENARIO *(It would be a different product, with stricter security requirements)*

A **time switch connected via Bluetooth** is used to control the automatic switching on and off of industrial equipment, such as pumps, generators, critical lighting, or cooling systems in a **water treatment plant, electrical substation, or data center**.



OBJECTIVE

Consider what activities a company like Dinuy (SME) needs to do in order to ensure that the time switch shall be designed, developed, produced, maintained, and disposed of in such a way that they ensure an appropriate level of cybersecurity based on the risks across the entire lifecycle of the product.

Consider at least the following:

- Risk assessment and treatment
- Essential Cybersecurity Requirements
- Communication with relevant stakeholders
- Updates - lifecycle
- Documentation



Product configuration process

Time Switch



DINUY-Configure App

*First time after installing App:
Log in to the App or user register*



Scan available devices
Available devices visible
Select device to configure
App reads PIN
User must enter PIN if activated (no PIN by default)
Configure programs and PIN (if new)



Register user email (form)

Ask for ack by email

Send ack (validate user)



DINUY Cloud Server

Workshop input and activities

- **Presentation from Dinuy:** you will have the full presentation where the product (time-switch) including mobile and cloud will be presented along with product configuration, development process, risks assessment
- **Presentation on PT2 Security controls:** Presenting the security controls and workshop flows – mostly based on this material
- **Case Study Feedback:** we will ask to attendees to fill in some questionnaire to collect inputs in a structured way
- **What will happen:**
 1. There will be 10 coordinators assigned to 10 table onsite and each table will have assigned some risks to analyze
 2. There will be 10 coordinators assigned to 10 breakout rooms online and each breakout room will have assigned some risks to analyze
 3. The goal would be to analyze and assign the right security controls for the pre-assigned risk including writing down challenges and lesson learned
 4. Table coordinators will guide the attendees in moderating the discussion and fill in the Case Study Feedback
 5. The table coordinators will summarize the key points that will be then discussed in a closure session as a panel discussion



Thank you

VULNIR.com

info@vulnir.com



Workshop CRA on September 23rd Madrid/online

STAN4CR

The workshop is part of the STAN4CR project, funded by EISMEA (European Innovation Council and SMEs Executive Agency), The STAN4CR plays a pivotal role in the drafting process of harmonised standards to support CRA compliance.

The STAN4CR project aims to raise public awareness and actively involve key stakeholders in the standardization process.

The workshop and the STAN4CR project are funded by the European Union through the European Innovation Council and SMEs Executive Agency (EISMEA), under Grant Agreement No. 101196779.





Workshop CRA on September 23rd Madrid/online

Focus

The workshop will address the items 2-14 in the Standardization Request of CRA:

➤ **Cybersecurity requirements for products with digital elements – Generic Essential Security Requirements**

Establishing fundamental security requirements for products with digital elements, including authentication and access control mechanisms, cryptographic requirements and key management, secure communication protocols, data protection and privacy safeguards, and incident logging and monitoring capabilities.

Main objective

Present the preliminary content of the horizontal standards being developed to comply with items 2-14 in the Standardization Request of CRA. And to receive feedback and input/contributions from all stakeholders that are going to comply with the Cyber Resilience Act.



Draft agenda

09.30 Registration and Welcome Coffee

10.00 Opening and Introduction

10.15 Spanish Landscape: National Cybersecurity Strategy

10.30 Overview of the Cyber Resilience Act (CRA)

10:50 Introduction to Standardization and Workshop Objectives

11.10 Coffee Break

11.30 Workshop presentation: Cybersecurity Requirements for Products with Digital Elements

12:10 Start of the Dynamic Workshop: Case Study

13.00 Lunch

14.00 Continuation of the Dynamic Workshop: Case Study

15.30 Coffee break

16.05 Closure of the Dynamic Workshop: Case Study

16.40 Next Steps for CRA's Standardization Development

16.50 Closing Words and Thank You – Networking



Workshop CRA on September 23rd Madrid/online

❖ Date

- September 23rd 2025, from 09.30 AM to 05.00 PM

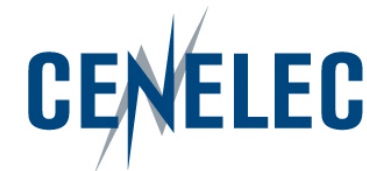
❖ Location

- Hotel NH Madrid Ventas, Madrid/online

❖ Registration (Required)

- [Registration form](#)
- [Workshop: Cyber Resilience Act and Horizontal Standards](#)





European Standardization Organizations

Thank you for your participation!

Upcoming webinars/events

2025-09-23 - [Workshop 'Cyber Resilience Act and Horizontal Standards'](#) (hybrid/Madrid)

CRA standards unlocked: [CRA Standards Unlocked – new webinar series launched - CEN-CENELEC](#)